

HELP DESK PROGRAMME

End Semester Examination - Computer Security Module

Computer Security (IT 209)

02 hours paper

04 Questions - Each question carries equal marks (25 Marks)

Question 1 - Lecture 01 - 04

Principles of Security - Lecture 01

CIA Triad, AAA Model, Computer Security Terminology, Threat Actor Types, Security Attacks

General Security Concepts - Lecture 02

Information Security Categorization

(Operational Security - network access control, authentication, security topologies)

(Physical security -

(Management security - guidance, rules, and procedures, Policies, Disaster recovery plans)

Identifying Potential Risks - Lecture 03

Dumpster diving, Eavesdropping, Snooping, Active and Passive attack, Denial-of-Service (DoS), Ping of Death, Buffer overflow, Distributed Denial-of-Service Attacks (DDoS), Botnet

Attack Methods - Lecture 04

TCP/IP Attacks, Spyware, Viruses, Worms, Impersonation, phishing

Question 2 - Lecture 07 - 08

Securing the Environment - Lecture 07

Attacks and Defenses- Layering, Limiting, Diversity, Obscurity, Simplicity

Security Policies and Procedures- Business Continuity, disaster recovery plan,

Infrastructure and Connectivity - Lecture 08

Internet, Intranet, Extranet, Demilitarized zone (DMZ), Packet filter, Stateful inspection firewall, Proxy firewall
Signature-Based Detection, Anomaly-Based Detection, Stateful Protocol Analysis, Network-Based IDPS, Host based IDPS

Question 3 - Lecture 09 and 10

Question 4 - Lecture 5 and 6

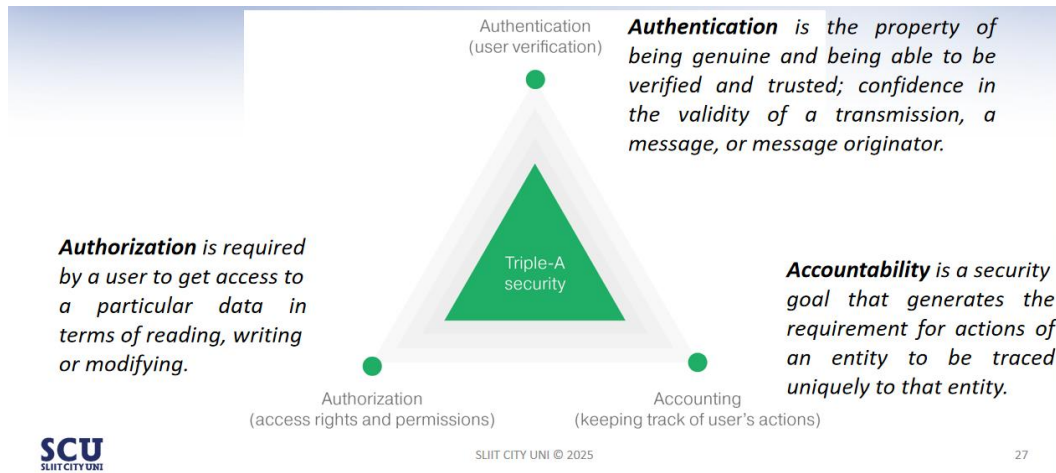
Past Paper - 2023 Semester 2 (January Intake)

Question 1

(25 marks)

- a) Define the term "Authentication".

(3 marks)



- b) "The CIA triad describes the three security objectives for information systems. For each security objective, we use three different levels of impact, such as low, moderate and high." The following are some examples of breaching of security. State which security objective has been breached and the levels of impact on organization/ individual information. (6 marks)

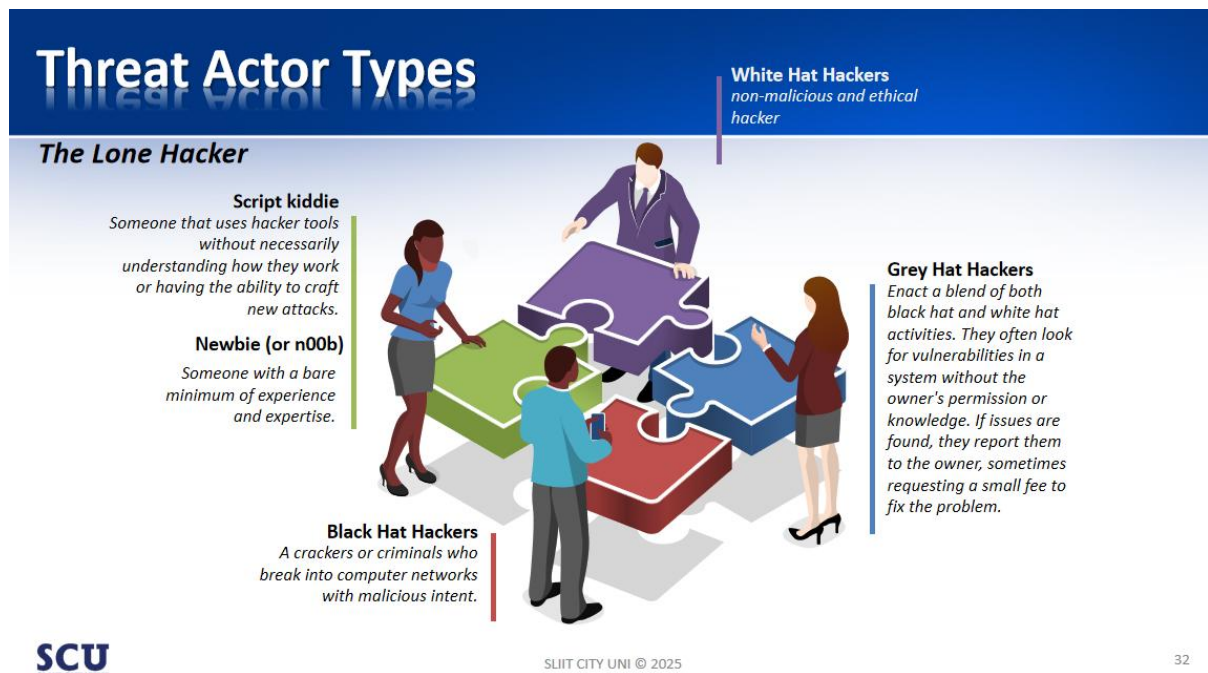
	Information System Assets	Security objective	Impact level
i)	An online telephone directory lookup application is temporarily down due to failure in the server.		
ii)	Student Grade information system which is available only to students, their parents, and academic staff has been hacked by an outsider to modify the final GPA.		
iii)	A freelancer works for several clients in the same industry and accidentally emails top secret business information to the wrong client.		

- c) Differentiate Script kiddie and Black Hat Hackers.

(4 marks)

Script Kiddie - Someone that uses hacker tools without necessarily understanding how they work or having the ability to craft new attacks.

Black hat hackers - A crackers or criminals who break into computer networks with malicious intent.



- d) Three key concepts in security are authentication, authorization and accountability. With an aid of an example, explain the concept of accountability. (4 marks)

Accountability is a security goal that generates the requirement for actions of an entity to be traced uniquely to that entity.

Access Logs in a Bank's Online System:

Suppose a bank has an online system where customers can view and transfer money. Each time a customer logs in, performs a transaction, or accesses sensitive information, the system records the activity in an access log. These logs include details such as:

- ❖ Who (user identity),
- ❖ What (action taken),
- ❖ When (timestamp),
- ❖ Where (IP address or device).

If any suspicious activity occurs, such as an unauthorized transfer, the bank can trace back the action to the specific user account or device and investigate further.

This ensures that individuals are held accountable for their actions and helps prevent unauthorized access or modifications to sensitive data.

- e) "Social networks have become a trusted communication medium for both personal and professional communication. However, this has become a powerful tool used for Social Engineering attacks by hackers." Specify two methods that the attackers exploit the trust of the users of social networks for their own gain. (2 x 4 marks)

1 Phishing

Attackers send messages or posts that appear to come from trusted contacts, companies, or platforms. These messages often include malicious links or request sensitive information (e.g., passwords, OTPs). Because the message seems legitimate, users are more likely to click or respond.

2. Impersonation (Fake Profiles):

Attackers create fake accounts pretending to be someone the victim knows (friends, colleagues, or company officials). They build trust through interaction and then manipulate the victim into sharing confidential information, sending money, or granting access to systems

Question 2

(25 marks)

- a) What is meant by Non-disaster disruptions in business continuation plans? (2 marks)

Non-disaster disruptions in business continuity plans refer to events that interrupt normal business operations but are not caused by major disasters like earthquakes or floods. These are usually internal or operational issues that can still affect productivity and services.

Examples include: System failures or server crashes, Power outages or network issues , Human errors or misconfigurations, Software bugs or cyber incidents

- b) State two examples of threats that an organization faces. (2 x 2 marks)

❖ **Malware Attacks** (e.g., viruses, ransomware):

Malicious software can infect systems, steal data, or disrupt operations.

❖ **Unauthorized Access** (Hacking):

Attackers may gain access to systems or networks to steal, modify, or destroy sensitive information.

c) "A proxy firewall can be thought of as an intermediary between your network and any other network."

i) What is meant by a Proxy firewall? (3 marks)

ii) A proxy firewall typically works as a dual-homed firewall. Briefly explain how dual-homed firewall operates. (3 marks)

What is meant by a Proxy Firewall?

A proxy firewall can be thought of as an intermediary between your network and any other network. Proxy firewalls are used to process requests from an outside network; the proxy firewall examines the data and makes rule-based decisions about whether the request should be forwarded or refused.

The proxy intercepts all the packages and reprocesses them for use internally. This process includes hiding IP addresses.

Requests from internal network users are routed through the proxy.

ii) Explain how a Dual-Homed Firewall Operates.

A Dual-homed firewall has two network interfaces: one connected to an internal trusted network and the other connected to an external untrusted network (e.g., the internet). The firewall filters traffic between the two networks, ensuring that only authorized communications can pass through. By having separate network interfaces, it acts as a barrier, preventing direct communication between the two networks and ensuring secure isolation of the internal network from external threats. This configuration provides enhanced security by controlling traffic flow and protecting the internal network from external attacks.

d) Differentiate the Network-Based Intrusion Detection Systems (NIDS) and the Host-Based Intrusion Detection Systems (HIDS). (5 marks)

Feature	Network-Based Intrusion Detection Systems (NIDS)	Host-Based Intrusion Detection Systems (HIDS)
---------	--	---

Location	Monitors network traffic across multiple devices and systems.	Monitors activities on a specific host or device (e.g., server or workstation).
Scope of Detection	Focuses on analyzing traffic for suspicious activity or attacks across the entire network.	Focuses on detecting intrusions on the host machine itself, such as unauthorized changes to system files or configurations.
Data Monitored	Monitors network traffic, protocols, and packets to detect attacks like DDoS or port scanning.	Monitors system files, processes, and logs for signs of malicious activities or policy violations.
Response to Intrusions	Alerts based on suspicious traffic patterns or attacks in the network environment.	Alerts based on changes or suspicious activity on a specific host system (e.g., file modifications or unauthorized logins).
Performance Impact	Minimal impact on the individual devices, as it monitors the network traffic externally.	May affect the performance of the host as it constantly monitors system activities locally.

- e) Consider the Figure 1 – Network topology to configure extended ACL (4 x 2 marks)
using the network policy given below. State what are the four ACL configurations required to implement in Router R1.

Network policy: For the 192.168.11.0/24 network, allow TFTP access and web access to the corporate Web/TFTP server at 192.168.20.254. Block all other traffic from the 192.168.11.0/24 network to the 192.168.20.0/24 network. All other access is allowed.

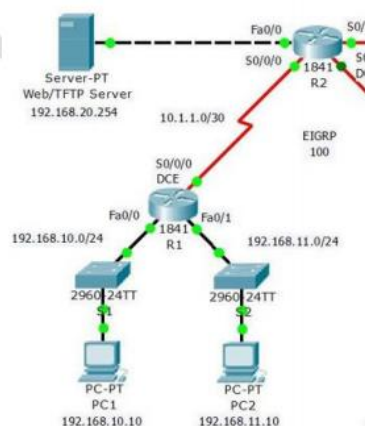


Figure 1 – Network topology

- ❖ Allow Web/TFTP access from the 192.168.11.0/24 network to the Web/TFTP server at 192.168.20.254:

```
access-list 100 permit tcp 192.168.11.0 0.0.0.255 host 192.168.20.254 eq www
```

```
access-list 100 permit udp 192.168.11.0 0.0.0.255 host 192.168.20.254 eq tftp
```

- ❖ Deny other traffic from the 192.168.11.0/24 network to the 192.168.20.0/24 network:

```
access-list 100 deny ip 192.168.11.0 0.0.0.255 192.168.20.0 0.0.0.255
```

- ❖ Allow all other traffic from the 192.168.11.0/24 network to the rest of the network:

```
access-list 100 permit ip 192.168.11.0 0.0.0.255 any
```

- ❖ Apply the ACL to the appropriate interface:

```
interface Fa0/0
```

```
ip access-group 100 in
```

Past Paper - 2024 Semester 2 (July/October Intake)

Question 1

(25 marks)

- a) Define the term “Integrity”.

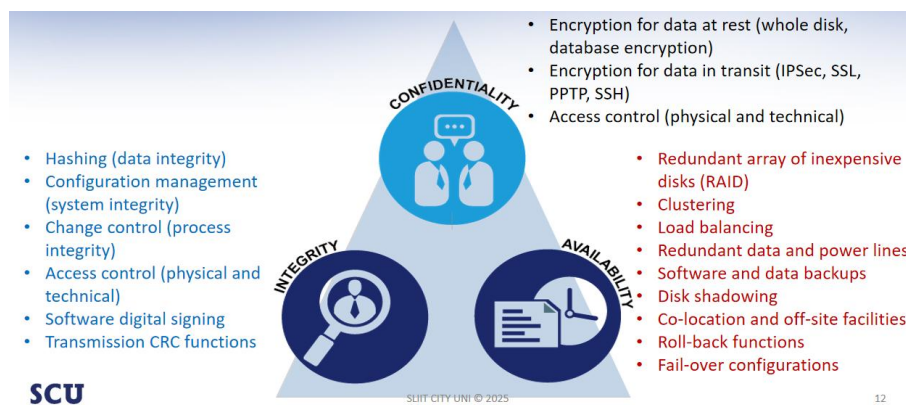
(3 marks)

Integrity is upheld when the assurance of the accuracy and reliability of information and systems is provided, and any unauthorized modification is prevented.

Integrity covers two related concepts:

- ❖ Data integrity: Assures that information and programs are changed only in a specified and authorized manner.
- ❖ System integrity : Assures that a system performs its intended function in an unimpaired manner, free from deliberate or inadvertent unauthorized manipulation of the system.

- b) List three mechanisms to reduce breaches in the integrity of operational security. (3 x 2 marks)



I. Implementing Strong Access Control:

- ❖ By enforcing **Role-Based Access Control (RBAC)** it ensure that only authorized individuals have access to critical systems and data. This reduces the risk of unauthorized changes or modifications to the system, protecting the integrity of the operational environment.

II. Regular Audits and Monitoring:

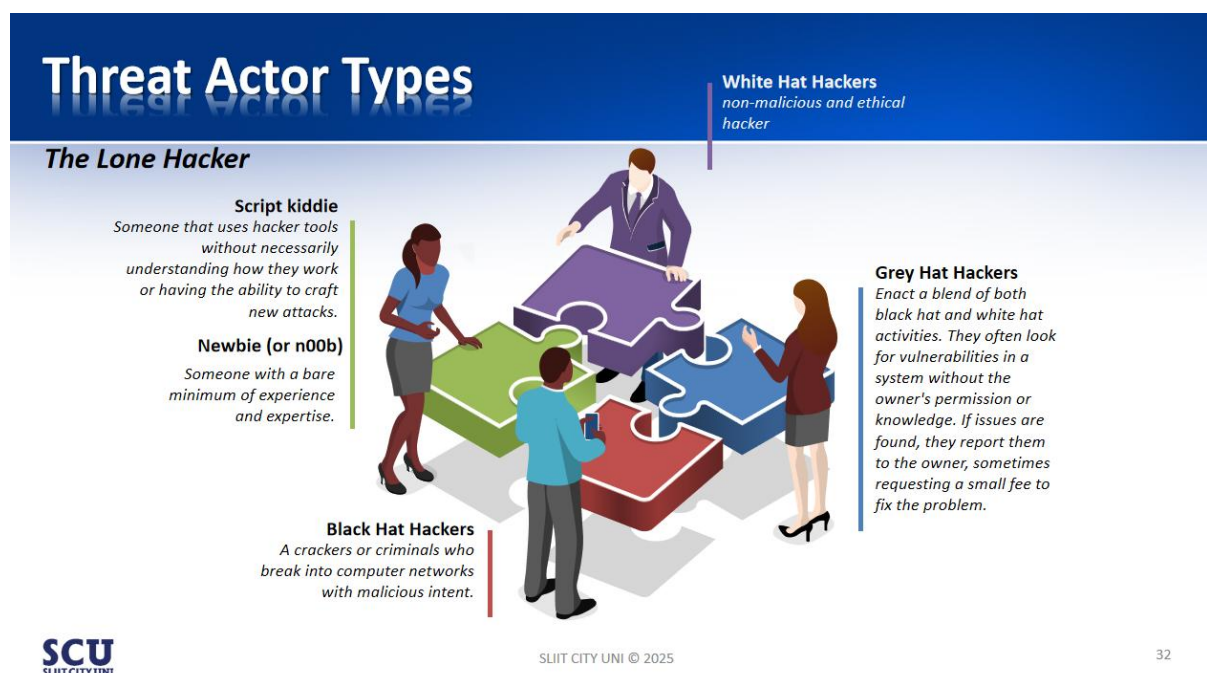
- ❖ Conducting routine system audits and real-time monitoring helps to identify and respond to suspicious activities or unauthorized actions promptly. This ensures that any potential breaches in data integrity are detected early, minimizing the impact.

III. Data Integrity Checks and Hashing:

- ❖ Implementing hashing algorithms (e.g., SHA-256) to verify the integrity of critical data helps ensure that it hasn't been tampered with. Regular integrity checks can identify if any data has been altered or corrupted, providing early detection of breaches.

c) Differentiate Grey hat hackers and Organized crime.

(4 marks)



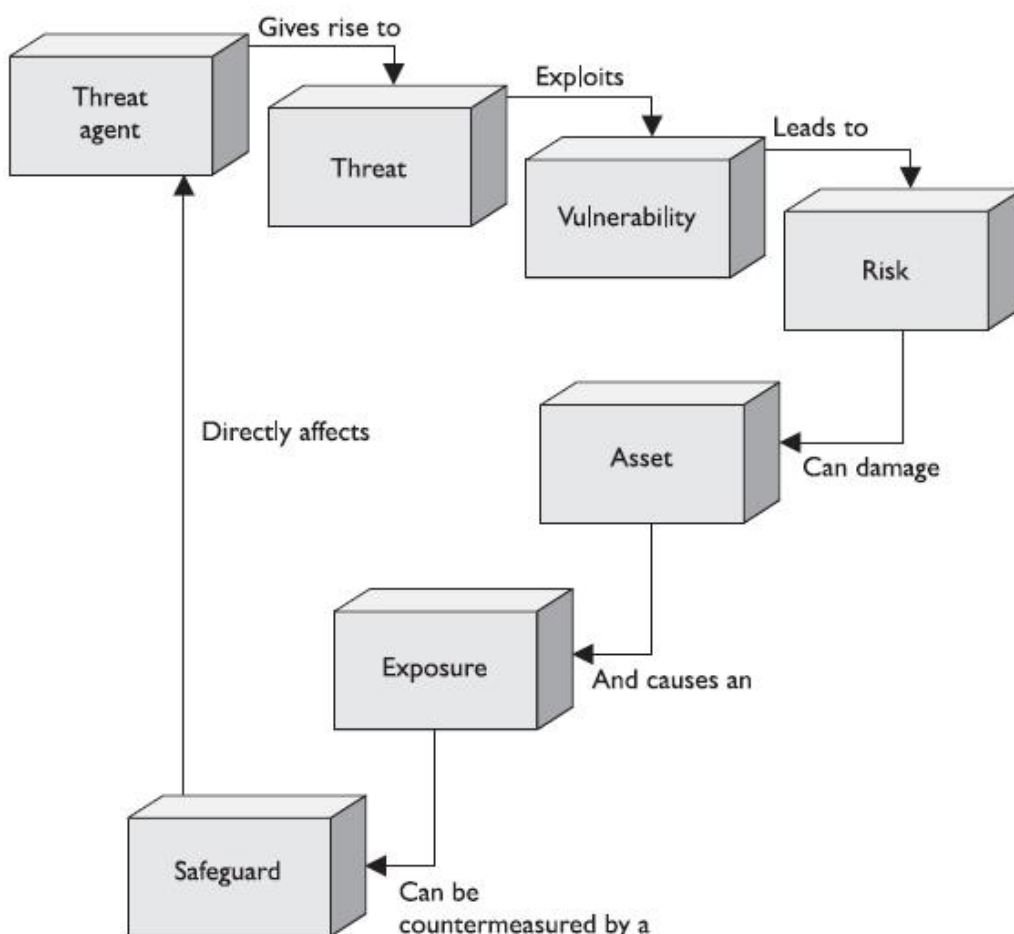
Gray Hat Hackers - Enact a blend of both black hat and white hat activities. They often look for vulnerabilities in a system without the owner's permission or knowledge. If issues are found, they report them to the owner, sometimes requesting a small fee to fix the problem.

Organized crime - can operate across the Internet from different authorities to their victims, increasing the complexity of actions. Organized crime will seek any opportunity for criminal profit, but typical activities are financial fraud (both against individuals and companies) and blackmail.

- d) Distinguish between a threat and a risk regarding information security. (4 marks)

Threat - A potential for violation of security, which exists when there is a circumstance, capability, action, or event, that could breach security and cause harm. That is, a threat is a possible danger that might exploit a vulnerability.

Risk - An expectation of loss expressed as the probability that a particular threat will exploit a particular vulnerability with a particular harmful result.



- e) Justify the statement "Social media profiles are rich resources for identity thieves." is true by providing two reasons. (2 x 4 marks)

1. **Personal Information Availability:**

Social media profiles often include personal details such as full names, birthdates, addresses, and phone numbers. This information is vital for identity thieves to impersonate individuals, conduct phishing attacks, or even apply for loans or credit cards.

2. **Security Question Answers:**

Many people use social media to share answers to security questions commonly asked by online platforms (e.g., mother's maiden name, pet names, etc.). This information can help attackers bypass account security measures and gain access to sensitive accounts by using it in phishing or impersonation attacks.

3. **Phishing:**

Social media provides attackers with the personal information needed to craft convincing phishing emails or messages. These messages often trick victims into disclosing passwords, credit card numbers, or other private information by pretending to be from trusted entities (e.g., banks or service providers).

4. **Impersonation:**

Attackers can use information from social media to impersonate a person. They might pose as someone familiar to the target (e.g., friends or colleagues) to manipulate the victim into sharing confidential information, such as account credentials or personal details.

5. **Vishing** (Voice Phishing):

Vishing occurs when identity thieves use information from social media to impersonate trusted figures over the phone. For instance, they might call pretending to be a bank representative, using personal details from social media to gain the victim's trust and trick them into revealing sensitive data, like credit card numbers or account PINs.

Question 2

(25 marks)

a) What is meant by Catastrophe disruptions in business continuation plans?

(2 marks)

Catastrophic disruptions in business continuity plans refer to **major and severe events that cause a significant and unexpected interruption to an organization's operations.** These disruptions typically result from **large-scale disasters such as natural disasters** (e.g., earthquakes, floods, hurricanes), fires, or extreme technological failures (e.g., massive data center outages). These events can severely affect the ability to continue essential business functions and require immediate and comprehensive response plans to recover.

b) State two reasons to implement separation-of-duties policies for an organization. (2 x 2 marks)

❖ **Preventing Fraud and Collusion:**

By separating duties, no single individual can complete all steps of a critical process, reducing the opportunity for fraud or unauthorized actions. This ensures that collusion is required for malicious activities, making it harder for fraud to occur without detection.

❖ **Reducing Errors and Risk:**

Separating responsibilities ensures that tasks are reviewed by different individuals, minimizing the risk of human error. It also provides a system of checks and balances, where mistakes or omissions are more likely to be caught before they affect the organization's operations.

c) "The Network Administrator suggests that having a Honeypot would protect your network."

i) What is meant by a Honeypot? (3 marks)

ii) How does a Honeypot can be used to protect your network? (4 marks)

A honeypot is a decoy system or resource that is intentionally set up to attract cyber attackers. It simulates a legitimate part of a network and appears vulnerable to entice attackers into interacting with it. However, its primary purpose is to gather information about attack methods, behaviors, and tools used by the attackers without putting the actual network at risk.

ii) How does a Honeypot protect your network?

A honeypot can protect your network in the following ways:

1. Distraction for Attackers:

By drawing attackers' attention away from critical systems, a honeypot keeps them engaged in a controlled environment where their actions can be closely monitored and studied.

2. Early Threat Detection:

Honeypots can detect new or unknown attack techniques by logging malicious activity. It serves as an early warning system for potential vulnerabilities in the network.

3. Gathering Intelligence:

Honeypots collect valuable information about attackers, including the methods, tools, and exploits they use. This intelligence can help strengthen overall network security by improving threat mitigation strategies.

4. Preventing Attacks on Real Systems:

Since attackers target the honeypot, the real network remains unaffected, reducing the risk of actual damage or data loss from the attackers.

- d) Consider the Figure 1 – Network topology to configure static NAT and extended ACL using the network requirements given below.

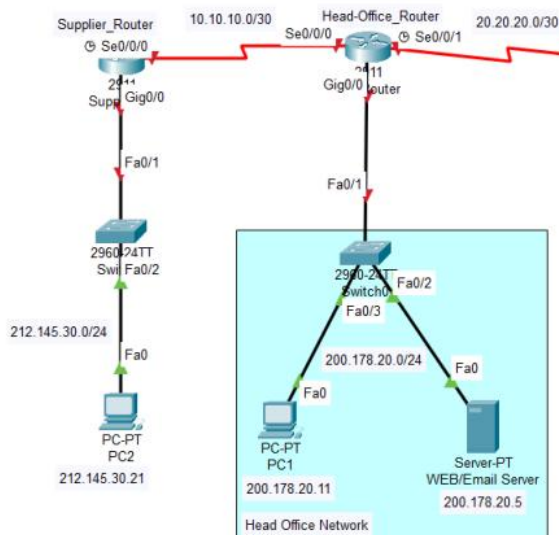


Figure 1 – Network topology

- i) The Head office network has a public IP of 100.178.20.0/24. (2 x 2 marks)

Configure Static NAT and map both PC1 and Server to its public IPs.

Use the corresponding host IDs.

PC1: 200.178.20.11 ---> 100.178.20.11

Server: 200.178.20.5 ---> 100.178.20.5

LAN side = inside

interface GigabitEthernet0/0

ip nat inside

exit

WAN/ISP side = outside

interface Serial0/0/0

ip nat outside

exit

interface Serial0/0/1

ip nat outside

exit

Static NAT mappings using same host IDs

ip nat inside source static 200.178.20.11 100.178.20.11

ip nat inside source static 200.178.20.5 100.178.20.5

- ii) State what are the three ACL configurations require to implement in (3 x 2 marks)
Supplier Router.

Network policy: Allow web traffic coming from PC2, host at 212.145.30.21 to the corporate WEB/Email server at 200.178.20.5 (use the public IP of server). Block Telnet access coming from 212.145.30.0/24 network to all locations. All other access is allowed.

access-list 100 permit tcp host 212.145.30.21 host 100.178.20.5 eq www

access-list 100 permit tcp host 212.145.30.21 host 100.178.20.5 eq smtp

access-list 100 permit tcp host 212.145.30.21 host 100.178.20.5 eq pop3

access-list 100 permit tcp host 212.145.30.21 host 100.178.20.5 eq imap

access-list 100 deny tcp 212.145.30.0 0.0.0.255 any eq telnet

access-list 100 permit ip any any

! Apply on Supplier Router (LAN interface - inbound)

```
interface GigabitEthernet0/0
```

```
ip access-group 100 in
```

```
exit
```

The three ACL requirements are:

1. Permit web/email traffic from PC2: 212.145.30.21 to server public IP: 100.178.20.5.
2. Deny Telnet from 212.145.30.0/24 to all destinations.
3. Permit all other traffic.

iii) Write the configuration to apply the ACL into the Router interface. (2 marks)

Past Paper - 2024 Semester 2 (February Intake)

Question 1

(25 marks)

a) Define the term "Availability".

(3 marks)

Availability protection ensures reliability and timely access to data and resources to authorized individuals.

b) List three mechanisms to reduce breaches in the availability of operational security. (3 x 2 marks)

1. **Implement Redundancy:**

Redundant systems (e.g., power supplies, network connections, or servers) ensure that if one part of the system fails, there is a backup ready to take over, reducing the risk of downtime or service interruptions.

2. **Distributed Denial-of-Service (DDoS) Protection:**

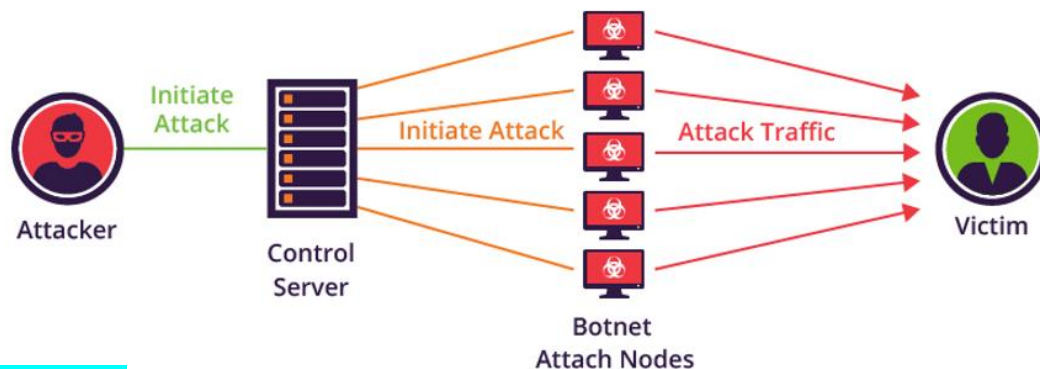
Deploying DDoS mitigation techniques, such as rate limiting, traffic filtering, and utilizing cloud-based DDoS protection services, helps prevent overload attacks on servers, ensuring continued availability.

3. **Regular Data Backups:**

Frequent and secure data backups ensure that if there is a system failure, data can be quickly restored, minimizing downtime and ensuring the availability of critical operational data

c) With aid of a diagram briefly explain how botnet attack operates. (4 marks)

A botnet is a group of hijacked Internet-connected devices, each injected with malware used to control it from a remote location without the knowledge of the device's rightful owner.



❖ Attacker:

The attacker is the individual or group who controls the botnet. They initiate the attack remotely using a control server.

❖ Control Server:

The control server is where the attacker sends instructions to the infected devices, known as botnet nodes or zombies. The attacker commands the botnet nodes to carry out the attack on the victim.

❖ Botnet Nodes (Infected Devices):

Botnet nodes are compromised devices (such as computers, smartphones, or IoT devices) that have been infected with malware. These nodes are controlled by the attacker without the knowledge of the legitimate device owner.

The infected devices receive the attack instructions from the control server.

❖ Initiate Attack:

The control server instructs the botnet nodes to start sending malicious attack traffic to the target or victim's system.

The botnet nodes flood the victim with traffic, causing a Denial-of-Service (DoS) or Distributed Denial-of-Service (DDoS) attack, depending on the number of nodes involved.

❖ Victim:

The victim is the **target of the botnet attack**, and their system is overwhelmed with traffic from the botnet nodes, causing it to become unavailable, slow, or even crash.

- e) Specify two major reasons and briefly explain why social engineering attacks are often more successful than technical hacks. (2 x 4 marks)

1. Exploitation of Trust through Impersonation:

Social engineering attacks, such as impersonation (e.g., masquerading as a trusted individual like a colleague or authority figure), exploit the trust of the target. Attackers may pose as legitimate entities (e.g., customer support or internal personnel) to gain access to sensitive information or resources, making it difficult for the victim to recognize the deception.

2. Phishing Attacks:

Phishing attacks deceive individuals into providing personal or confidential information. Phishing typically involves mass emails with fraudulent links or attachments, while spear phishing targets specific individuals or organizations with highly personalized messages. These attacks often bypass technical security defenses by preying on human error rather than system vulnerabilities.

3. Whaling Attacks:

Whaling is a targeted form of phishing aimed at high-ranking executives or individuals with access to sensitive data. Attackers use social engineering to craft emails or messages that appear to be from trusted sources, such as legal departments or business partners, to manipulate the target into disclosing confidential information or approving fraudulent transactions.

Question 2

(25 marks)

- a) What is meant by "Disaster" disruptions in business continuation plans? (2 marks)

An unexpected event that significantly interrupts normal business operations and prevents an organization from functioning properly.

Key points:

- It can be natural (e.g., floods, earthquakes) or man-made (e.g., cyberattacks, power failures).
- Causes system downtime, data loss, or service unavailability.
- Requires a recovery strategy to restore operations quickly.

b) State two reasons to implement acceptable-use policies for an organization. (2 x 2 marks)

Enhance Security

Prevent misuse of systems that could lead to malware infections, data breaches, or cyberattacks.

Protect Organizational Data

Ensure sensitive information is handled properly and not leaked or misused.

Define User Responsibilities

Clearly inform employees about what is allowed and prohibited when using IT resources.

Ensure Legal and Regulatory Compliance

Help the organization comply with laws, regulations, and industry standards.

Improve Productivity

Reduce non-work-related activities (e.g., excessive social media use), ensuring efficient use of resources.

c) "Several monitoring mechanisms are available to track traffic. Monitoring can occur on individual systems, on servers, or as a separate component of the network."

i) What is meant by a Host-Based IDS (HIDS)? (3 marks)

ii) Briefly explain one major problem with HIDS. (4 marks)

A Host-Based Intrusion Detection System (HIDS) is A security system installed on an individual computer or server that monitors and analyzes its activities to detect suspicious or unauthorized behavior.

Key points:

Runs on a specific host (PC/server)

Monitors files, system logs, processes, and user activities

Detects malware, unauthorized access, or policy violations

High Resource Usage

HIDS runs on individual hosts and consumes CPU, memory, and storage, which can affect system performance.

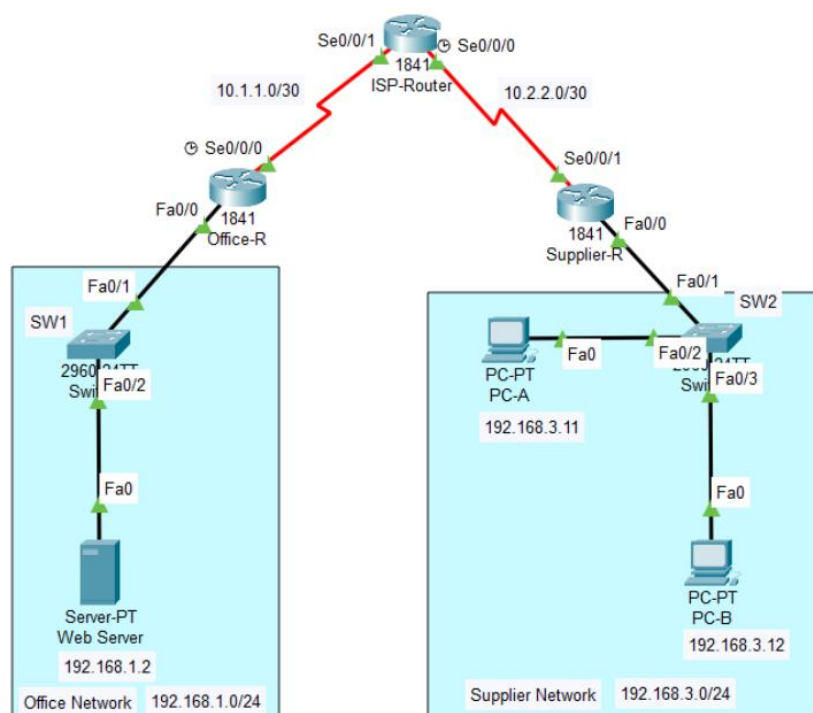
Difficult to Manage at Scale

Requires installation and maintenance on every host, making it complex in large networks.

Limited Network Visibility

Monitors only the specific host, so it cannot detect attacks happening elsewhere in the network.

- d) Consider the Figure 1 – Network topology to configure static NAT and extended ACL using the network requirements given below.



NOTE: Assume basic configurations and EIGRP dynamic routing configurations are completed.

- i) The office network has a public IP of 200.178.10.0/24. Configure (3 marks)
public IP 200.178.10.2 for Web server using static NAT method.

Web Server private IP: 192.168.1.2

Web Server public IP: 200.178.10.2

```
interface FastEthernet0/0
```

```
ip nat inside
```

```
exit
```

```
interface Serial0/0/0
```

```
ip nat outside
```

```
exit
```

```
ip nat inside source static 192.168.1.2 200.178.10.2
```

- ii) The office router then configures with AutoSecure CBAC firewall and (3 marks)
hardens the router configurations. Figure 2 shows the current state of
the ACL configuration and notification display on the office Router.
Briefly explain the reason to get 135 matches on ACL.

```
Office-R#show access-lists autosec_firewall_acl
Extended IP access list autosec_firewall_acl
    permit udp any any eq bootpc
    deny ip any any (135 match(es))
```

```
*Mar 01, 04:26:49.2626: %DUAL-5-NBRCHANGE: IP-EIGRP 100: Neighbor 10.1.1.2
(Serial0/0/0) is down: deny ip any any
```

Figure 2 – ACL configuration and notification

The 135 matches on the ACL occur because:

The rule deny ip any any is blocking all traffic that is not explicitly permitted,
and every denied packet is counted as a match.

Explanation:

- Only DHCP traffic (bootpc) is allowed.
- All other traffic (including routing protocols like EIGRP) is denied.
- The router log shows EIGRP neighbor going down, meaning routing packets are being blocked.
- Each blocked packet increments the ACL counter → resulting in 135 matches.

iii) Write ACL configurations to allow EIGRP updates by adding a (3 marks)
statement to the extended ACL `autosec_firewall_acl`.

```
ip access-list extended autosec_firewall_acl
permit eigrp any any
exit
```

Explanation:

- EIGRP uses protocol 88, not TCP/UDP.
- This rule allows routing updates between routers.
- It must be placed above deny ip any any, otherwise it will still be blocked.

iv) Configure an ACL to allow Telnet access to office router by adding a (3 marks)
statement to the extended ACL `autosec_firewall_acl`.

```
ip access-list extended autosec_firewall_acl
permit tcp any any eq telnet
exit
```

This must be placed above deny ip any any.

Telnet uses TCP port 23.

Past Paper - 2025 Semester 2 (October Intake)

Question 1

(25 marks)

a) Define the term "Accountability". (3 marks)

Accountability is a security goal that generates the requirement for actions of an entity to be traced uniquely to that entity.

b) With the aid of examples, list two methods for implementing the concept of accountability across the organization. (2 x 3 marks)

Clear Role Definitions and Responsibilities:

Example: In a company, each employee has a clear job description that specifies their roles, tasks, and deliverables. This ensures they are accountable for their assigned duties. For instance, the IT department is responsible for maintaining network security, and failure to do so could result in security breaches. This allows the organization to hold individuals accountable for their performance and actions within their designated roles.

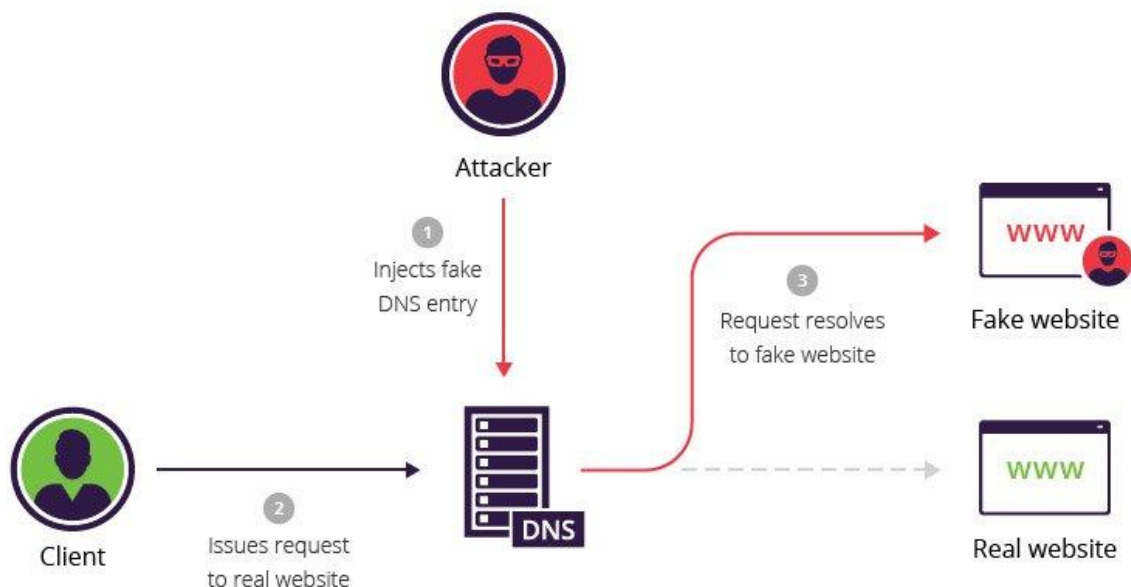
Auditing and Monitoring Systems:

Example: Implementing logging and monitoring tools like Security Information and Event Management (SIEM) systems to track employee activities on corporate systems. For example, if a user accesses sensitive customer data, the system logs the action, ensuring that any unauthorized access can be traced and held accountable. This creates a transparent system where actions are tracked, and individuals can be held accountable for their decisions and actions.

c) With aid of a diagram briefly explain how DNS spoofing attack operates. (4 marks)

DNS spoofing or DNS poisoning, the DNS server is given information about a name server that it thinks is legitimate when it isn't.

DNS Spoofing (also known as DNS Cache Poisoning) is a type of cyber attack in which a malicious actor manipulates the Domain Name System (DNS) data to redirect traffic from a legitimate website to a fraudulent one. This occurs when the DNS resolver's cache is poisoned with fake or altered entries.



d) Differentiate Black Hat hackers and Grey Hat hackers.

(4 marks)

Grey Hat hackers - Enact a blend of both black hat and white hat activities. They often look for vulnerabilities in a system without the owner's permission or knowledge. If issues are found, they report them to the owner, sometimes requesting a small fee to fix the problem.

Black Hat hackers - A crackers or criminals who break into computer networks with malicious intent

e) "Social networks have become a trusted communication medium for both personal and professional communication. However, this has become a powerful tool used for Social Engineering attacks by hackers." Specify two methods that the attackers exploit the trust of the users of social networks for their own gain. (2 x 4 marks)

a) What is the main goal of "Layering" in defense in depth?

(2 marks)

By using multiple security measures, such as firewalls, intrusion detection systems (IDS), encryption, and authentication, organizations can ensure that if one defense layer is breached, others remain intact to prevent a successful attack.

b) Answer the following questions about Anomaly-based IDS.

i) Briefly explain how an Anomaly-based IDS works.

(3 marks)

An Anomaly-based Intrusion Detection System (IDS) works by establishing a baseline of normal network behavior (e.g., traffic patterns, system resource usage, and application behavior). It then continuously monitors network activities and compares them to the baseline. Any activity that deviates significantly from the normal behavior is flagged as an anomaly and is considered potentially malicious.

Key Points:

- Learning Phase: The system first "learns" what is normal, often using statistical methods or machine learning.

- Detection Phase: It compares current network activity with the baseline. If there is a significant deviation (anomaly), the system generates an alert.

Example:

If a server typically handles 100 requests per minute, but one day it suddenly receives 1000 requests, the IDS would flag this as an anomaly and potentially a DoS (Denial of Service) attack.

- ii) With aid of an example briefly explain the main criticism of anomaly based IDPS when compared with signature based IDPS. (6 marks)

The primary criticism of Anomaly-based IDS is the high rate of false positives. Since anomaly-based systems rely on comparing current activity to a learned baseline, any deviation—whether benign or malicious—can be flagged as an anomaly. This means the system might incorrectly flag normal behavior as suspicious, leading to unnecessary alerts.

Example:

Imagine a company's website experiences a surge in traffic during a product launch. An anomaly-based IDS might interpret this surge as an anomaly (deviation from the baseline traffic pattern), leading to false positives, even though the increased traffic is legitimate.

In contrast, a signature-based IDS would only trigger an alert if it detects a specific known malicious pattern (signature), making it less likely to generate false positives in this scenario.

Main Criticism:

Anomaly-based IDS: More false positives due to detecting deviations from normal behavior.

Signature-based IDS: More accurate alerts as it relies on known attack signatures but is unable to detect new or unknown attacks.

- c) Differentiate what are Working copies and Offsite storage. (4 marks)

Working copies refer to the local copies of files that are actively being worked on by users. These are usually stored on the user's device or within the organization's system.

Example: A document you are editing on your computer or a project that is actively being worked on within a company's local server.

Offsite storage refers to the **backup of data stored at a physical location other than the primary site.** It is **typically used for disaster recovery** and to secure critical data.

Example: A cloud storage solution where critical company files are periodically backed up, or a data center located in a different geographic region from the main office.

- d) Consider the Figure 1 – Network topology and configure using the network requirements given below.

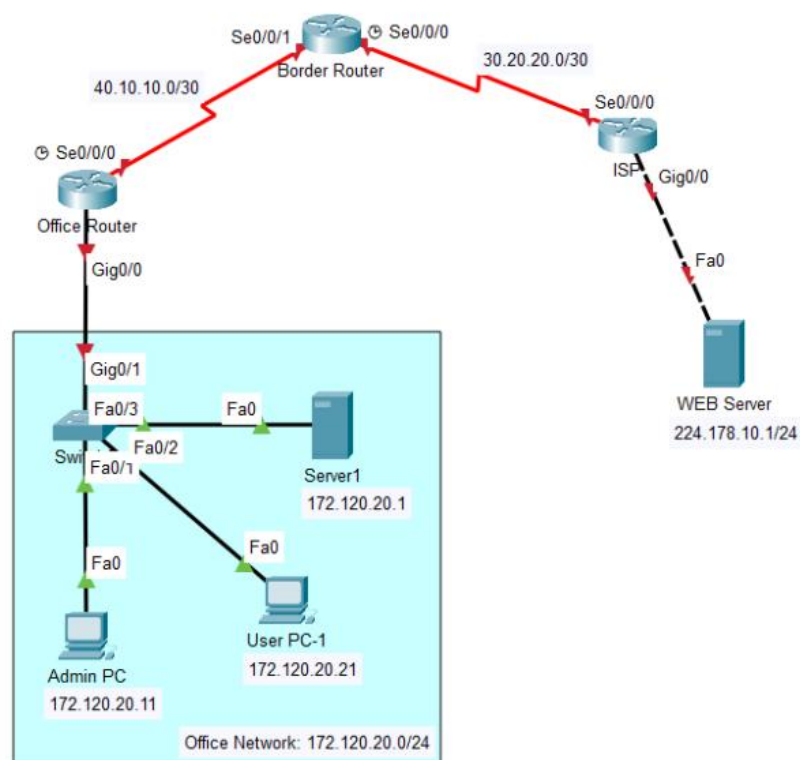


Figure 1 – Network topology

NOTE: Assume basic configurations and EIGRP dynamic routing configurations are completed.

- i) The Office network has a public IP of 124.220.120.0/24. Configure public IP 124.220.120.1 for Server1 using static NAT method.

```
interface GigabitEthernet0/1
ip nat inside
exit
```

```
interface Serial0/0/1
ip nat outside
exit
```

! Static NAT configuration

```
ip nat inside source static 172.120.20.1 124.220.120.1
end
write memory
```

Explanation:

172.120.20.1 is the private IP of Server1.

124.220.120.1 is the public IP you want to map to the server.

ip nat inside and ip nat outside define which interfaces are used for internal and external traffic.

- ii) The public IP of the office network requires to configure with dynamic NAT for Admin PCs IP addresses range from 124.220.120.11 to 124.220.120.20. Create a dynamic NAT pool named as ADMIN, assuming that the standard access list configurations are completed. (4 marks)

```
ip nat pool ADMIN 124.220.120.11 124.220.120.20 netmask 255.255.255.0
Exit
```

```
access-list 1 permit 172.120.20.0 0.0.0.255
Exit
```

```
ip nat inside source list 1 pool ADMIN overload
Exit
```

ip nat pool ADMIN creates a NAT pool with the public IP range from 124.220.120.11 to 124.220.120.20.

Access List 1 permits the Admin PCs IP range 172.120.20.0/24 (for example).

overload option allows multiple internal addresses to map to a single public IP in the pool.

- iii) The Office-Router then configures with AutoSecure CBAC firewall and hardens the router configurations. Figure 2 shows the current state of the ACL configuration display on the Office-Router. Write ACL configurations to allow remote access via Telnet by adding a statement to the extended ACL `autosec_firewall_acl`. (3 marks)

```
Office-R#show access-list autosec_firewall_acl
Extended IP access list autosec_firewall_acl
 10 permit udp any any eq bootpc
 14 permit eigrp any any (15 matches)
 20 deny ip any any (57 matches)
```

Figure 2 – ACL configuration


```
! Add the rule to allow Telnet (TCP port 23)
ip access-list extended autosec_firewall_acl
permit tcp any any eq telnet
exit
```

```
end
write memory
```

permit tcp any any eq telnet allows Telnet traffic (TCP port 23) from any source to any destination.

Ensure this statement is placed above the deny ip any any rule in the ACL to allow Telnet access.